

Experiment No. 1

Aim:

Study of Different Laws and Standards of Cyber Security

What is Cyber Security?

The technique of protecting internet-connected systems such as computers, servers, mobile devices, electronic systems, networks, and data from malicious attacks is known as cybersecurity. We can divide cybersecurity into two parts one is cyber, and the other is security. Cyber refers to the technology that includes systems, networks, programs, and data. And security is concerned with the protection of systems, networks, applications, and information. In some cases, it is also called electronic information security or information technology security.

Types of Cyber Security

Every organization's assets are the combinations of a variety of different systems. These systems have a strong cybersecurity posture that requires coordinated efforts across all of its systems. Therefore, we can categorize cybersecurity in the following sub-domains:

Network Security: It involves implementing the hardware and software to secure a computer network from unauthorized access, intruders, attacks, disruption, and misuse. This security helps an organization to protect its assets against external and internal threats.

Application Security: It involves protecting the software and devices from unwanted threats. This protection can be done by constantly updating the apps to ensure they are secure from attacks. Successful security begins in the design stage, writing source code, validation, threat modeling, etc., before a program or device is deployed.

Information or Data Security: It involves implementing a strong data storage mechanism to maintain the integrity and privacy of data, both in storage and in transit.

Identity management: It deals with the procedure for determining the level of access that each individual has within an organization.

Operational Security: It involves processing and making decisions on handling and securing data assets.

Mobile Security: It involves securing the organizational and personal data stored on mobile devices such as cell phones, computers, tablets, and other similar devices against various malicious threats. These threats are unauthorized access, device loss or theft, malware, etc.

Cloud Security: It involves in protecting the information stored in the digital environment or cloud architectures for the organization. It uses various cloud service providers such as AWS, Azure, Google, etc., to ensure security against multiple threats.

Security Standards:

To make cybersecurity measures explicit, the written norms are required. These norms are known as cybersecurity standards: the generic sets of prescriptions for an ideal execution of certain measures. The standards may involve methods, guidelines, reference frameworks, etc. It ensures efficiency of security, facilitates integration and interoperability, enables meaningful comparison of measures, reduces complexity, and provide the structure for new developments. A security standard is "a published specification that establishes a common language, and contains a technical specification or other precise criteria and is designed to be used

consistently, as a rule, a guideline, or a definition." The goal of security standards is to improve the security of information technology (IT) systems, networks, and critical infrastructures. The Well-Written cybersecurity standards enable consistency among product developers and serve as a reliable standard for purchasing security products.

Security standards are generally provided for all organizations regardless of their size or the industry and sector in which they operate. This section includes information about each standard that is usually recognized as an essential component of any cybersecurity strategy.

ISO

ISO stands for International Organization for Standardization. International Standards make things to work. These standards provide a world-class specification for products, services and computers, to ensure quality, safety and efficiency. They are instrumental in facilitating international trade.

ISO standard is officially established On 23 February 1947. It is an independent, non-governmental international organization. Today, it has a membership of 162 national standards bodies and 784 technical committees and subcommittees to take care of standards development. ISO has published over 22336 International Standards and its related documents which covers almost every industry, from information technology, to food safety, to agriculture and healthcare.

ISO 27000 Series

It is the family of information security standards which is developed by the International Organization for Standardization and the International Electrotechnical Commission to provide a globally recognized framework for best information security management. It helps the organization to keep their information assets secure such as employee details, financial information, and intellectual property.

The need of ISO 27000 series arises because of the risk of cyber-attacks which the organization face. The cyber-attacks are growing day by day making hackers a constant threat to any industry that uses technology.

The ISO 27000 series can be categorized into many types. They are-

ISO 27001- This standard allows us to prove the clients and stakeholders of any organization to managing the best security of their confidential data and information. This standard involves a process-based approach for establishing, implementing, operating, monitoring, maintaining, and improving our ISMS.

ISO 27000- This standard provides an explanation of terminologies used in ISO 27001.

ISO 27002- This standard provides guidelines for organizational information security standards and information security management practices. It includes the selection, implementation, operating and management of controls taking into consideration the organization's information security risk environment(s).

ISO 27005- This standard supports the general concepts specified in 27001. It is designed to provide the guidelines for implementation of information security based on a risk management approach. To completely understand the ISO/IEC 27005, the knowledge of the concepts, models, processes, and terminologies described in ISO/IEC 27001 and ISO/IEC 27002 is required. This standard is capable for allkind of organizations such as non-government organization, government agencies, and commercial enterprises.

ISO 27032- It is the international Standard which focuses explicitly on cybersecurity. This Standard includes guidelines for protecting the information beyond the borders of an organization such as in collaborations, partnerships or other information sharing arrangements with clients and suppliers.

IT Act

The Information Technology Act also known as ITA-2000, or the IT Act main aims is to provide the legal infrastructure in India which deal with cybercrime and e-commerce. The IT Act is based on the United Nations Model Law on E-Commerce 1996 recommended by the General Assembly of United Nations. This act is also used to check misuse of cyber network and computer in India. It was officially passed in 2000 and amended in 2008. It has been designed to give the boost to electronic commerce, e-transactions and related activities associated with commerce and trade. It also facilitates electronic governance by means of reliable electronic records.

IT Act 2000 has 13 chapters, 94 sections and 4 schedules. The first 14 sections concerning digital signatures and other sections deal with the certifying authorities who are licenced to issue digital signature certificates, sections 43 to 47 provide penalties and compensation, section 48 to 64 deal with appeal to high court, sections 65 to 79 deal with offences, and the remaining section 80 to 94 deal with miscellaneous of the act.

Copyright Act

The Copyright Act 1957 amended by the Copyright Amendment Act 2012 governs the subject of copyright law in India. This Act is applicable from 21 January 1958. Copyright is a legal term which describes the ownership of control of the rights to the authors of "original works of authorship" that are fixed in a tangible form of expression. An original work of authorship is a distribution of certain works of creative expression including books, video, movies, music, and computer programs. The copyright law has been enacted to balance the use and reuse of creative works against the desire of the creators of art, literature, music and monetize their work by controlling who can make and sell copies of the work.

The copyright act covers the following-

Rights of copyright owners

Works eligible for protection

Duration of copyright

Who can claim copyright

The copyright act does not covers the following-

Ideas, procedures, methods, processes, concepts, systems, principles, or discoveries

Works that are not fixed in a tangible form (such as a choreographic work that has not been notated or recorded or an improvisational speech that has not been written down)

Familiar symbols or designs

Titles, names, short phrases, and slogans

Mere variations of typographic ornamentation, lettering, or coloring

Patent Law

Patent law is a law that deals with new inventions. Traditional patent law protect tangible scientific inventions, such as circuit boards, heating coils, car engines, or zippers. As time increases patent law have been used to protect a broader variety of inventions such as business practices, coding algorithms, or genetically modified organisms. It is the right to exclude others from making, using, selling, importing, inducing others to infringe, and offering a product specially adapted for practice of the patent.

In general, a patent is a right that can be granted if an invention is:

Not a natural object or process

New

Useful

Not obvious.

IPR

Intellectual property rights is a right that allow creators, or owners of patents, trademarks or copyrighted works to benefit from their own plans, ideas, or other intangible assets or investment in a creation.

These IPR rights are outlined in the Article 27 of the Universal Declaration of Human Rights. It provides for the right to benefit from the protection of moral and material interests resulting from authorship of scientific, literary or artistic productions. These property rights allow the holder to exercise a monopoly on the use of the item for a specified period.

Information Technology Act, 2000

Information Technology (Certifying Authority) Rules, 2000 Information Technology (Security Procedure) Rules, 2004 Information Technology (Certifying Authority) Regulations, 2001

The IT Act is the key to guide the entire Indian law to strictly control cyber crimes (MEIT, 2000).

Section 43 – (damage to computer, computer system, etc.) applies to those who cause damage to computer system without the permission of the owner. In such cases the owner can claim compensation for the full loss.

Section 43A – (Corporate failure to protect data)

Section 44(a) – (failure to produce document, return or report to the controlling or certifying authority)

Section 44(b) – (Failure to file any return or to produce any information, books or other document within specified time)

Section 44(c) – (failure to maintain books of account or records) Section 45 – (Where no separate punishment has been awarded) Section 46 – (tampering with computer source documents)

Section 66 – Applicable in the case of any person referred to in section 43 dishonestly or fraudulently committing any act. In such cases the term of imprisonment may extend to three years or with fine which may extend to Rs. 5 lakhs.

Section 66A – Hacking with computer system, alteration of data etc.

Section 66B – Involves punishment for fraudulently obtaining stolen communication equipment or computers, which carries a sentence of imprisonment for a term which may extend to three years. This term can also be extended above Rs. 1 lakh fine depending on the severity.

Section 66C – This section investigates identity theft involving forged digital signatures, hacking passwords, or other unique identification features. to be proven guilty shall be punished with imprisonment of either description for a term which may extend to three years and shall also be liable to fine of one lakh rupees.

Section 66D – This section was inserted on-demand, with a focus on punishing fraudsters who impersonate by using computer resources.

Section 66E – Publishing obscene images Section 66F – Cyber terrorism

Section 67 – Publishes or transmits unsolicited material Section 67A – Publishes or transmits explicit sex Section 67B – abusing children online

Section 67C – Protection of information by arbitrator Section 70 – Unauthorized access to protected system

Section 71 – Misrepresentation to Controller or Certifying Authority for obtaining license or electronic signature certificate

Section 72 – Violation of confidentiality and confidentiality Section 73 and 74 – Publishing false digital signature certificates